COMPTIA SECURITY+ SY0-701 DOMÍNIO 1 · CONCEITOS GERAIS DE SEGURANÇA (12%)

Security+ 1.2 · The CIA Triad

Mestre CyberSec · **Aula 1.2 — The CIA Triad** (5:17) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: 3 objetivos: CONFIDENCIALIDADE (só quem deve, vê — encriptação, ACL, MFA, classificação); INTEGRIDADE (dado não é alterado indevidamente — hash, assinatura digital, certificado); DISPONIBILIDADE (serviço up — redundância, failover, patch, backup). Todo controle serve a pelo menos

💡 Highlights que a prova CompTIA cobra

- C ferida: leak/escuta. I ferida: alterado/fraudado. A ferida: serviço down.
- Hash dá I, NÃO C (não cifrar conteúdo)
- Assinatura digital dá I + autenticação + non-repudiation (o 3-em-1)
- AES = confidencialidade; RSA = troca de chave + assinatura
- 'which of the three goals was COMPROMISED' = a pergunta clássica

🎯 Dicas de Prova & Cenários Típicos da Banca

- Cenário 'alguém viu o dado'=C · 'alguém alterou'=I · 'não consigo acessar'=A
- Cuidado: 'email enviado por personagem não-autorizado' pode ser I (integridade do remetente) ou C se o conteúdo vazou

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 1.2 — The CIA Triad)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Tríade CIA

Modelo fundamental de segurança composto por três objetivos centrais: Confidencialidade, Integridade e Disponibilidade. Todo controle de segurança se encaixa em pelo menos um desses.

⚠ ***Armadilha CompTIA:*** *If a question asks 'which CIA goal was compromised?', match the symptom: data exposed/viewed = Confidentiality; data altered/falsified = Integrity; service down/unreachable = Availability.*

• Confidencialidade

Garante que os dados sejam acessíveis apenas a partes autorizadas. Implementada por meio de criptografia, listas de controle de acesso (ACLs), MFA e classificação de dados.

⚠ ***Armadilha CompTIA:*** *CompTIA trigger: 'data leaked, intercepted, or viewed by the wrong person' = Confidentiality breach. Controls: encryption, classification, ACL.*

• Integridade

Garante que os dados não foram modificados ou adulterados, estejam em repouso ou em trânsito. Implementada por hashing, assinaturas digitais e certificados.

⚠ ***Armadilha CompTIA:*** *CompTIA trigger: 'data altered, falsified, or modified by an unauthorized party' = Integrity breach. Hash is the #1 control tested here.*

• Disponibilidade (A)

Garante que sistemas e dados permaneçam acessíveis aos usuários autorizados quando necessário. Implementada por redundância, failover, patching e backups.

⚠ ***Armadilha CompTIA:*** *CompTIA trigger: 'service down, unreachable, DoS, or system offline' = Availability breach. Controls: redundancy, failover clusters, UPS, patching.*

• Hash (Hash Criptográfico) (N/A)

Função matemática unidirecional que produz uma saída de tamanho fixo (digest) representando o dado de entrada, usada para verificar Integridade — não Confidencialidade.

⚠️ ***Armadilha CompTIA:*** *KEY DISTINCTION: Hashing provides Integrity ONLY. It does NOT provide Confidentiality because the original data is still visible/readable — the hash only detects changes. Common algorithms: MD5, SHA-256.*

• Assinatura Digital (DS)

Operação criptográfica com chaves assimétricas que fornece Integridade, Autenticação e Não-repúdio em um único mecanismo — o controle de segurança '3 em 1'.

⚠️ ***Armadilha CompTIA:*** *CompTIA loves this combo: Digital Signature = Integrity + Authentication + Non-repudiation. If a question lists all three benefits, the answer is Digital Signature, not just hashing or encryption.*

• Não-Repúdio (NR)

Garantia de que o remetente não pode negar ter enviado uma mensagem ou executado uma ação. Obtida por assinaturas digitais e trilhas de auditoria criptográficas.

⚠️ ***Armadilha CompTIA:*** *Non-repudiation is unique to digital signatures and PKI — neither encryption nor hashing alone provides it. Watch for it bundled with Integrity and Authentication in answer choices.*

• Criptografia (AES / RSA)

AES (simétrica) fornece Confidencialidade embaralhando dados com uma chave compartilhada. RSA (assimétrica) é usada para troca de chaves e assinaturas digitais — não para criptografar grandes volumes.

⚠️ ***Armadilha CompTIA:*** *AES = Confidentiality ONLY. RSA = key exchange + digital signatures. The exam often asks 'which provides confidentiality?' — symmetric ciphers like AES are the answer, not hashing.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Confidencialidade: Proteção Contra Divulgação Não Autorizada

🏠 **Analogia Intuitiva:** Uma carta ultra-secreta escrita em código, selada dentro de um envelope opaco com lacre de cera, guardada dentro de uma gaveta trancada cuja chave só você possui. Qualquer pessoa que passar pelo corredor ou pegar o envelope não consegue ler nem uma única palavra do conteúdo.

🔍 **Causa Raiz / Por que foi criado:** Em redes de computadores abertas e ambientes de armazenamento compartilhado, pacotes de dados e arquivos podem ser interceptados por sniffer de rede ou roubados por invasores caso estejam em texto claro (plaintext).

🛡️ **Visão do Auditor de GRC:** O auditor fiscaliza a conformidade com leis de proteção de dados (LGPD, GDPR, HIPAA): verifica se dados em repouso utilizam criptografia forte (AES-256), se dados em trânsito exigem TLS 1.3, e se políticas de classificação de dados e Controle de Acesso Baseado em Funções (RBAC) impedem acessos indevidos.

⚠️ **Como cai na Prova CompTIA:** Gatilhos da prova: 'Snooping', 'Sniffing', 'Eavesdropping', 'Data exfiltration', 'Unauthorized viewing of confidential records'. A propriedade violada é sempre a Confidencialidade. Controles primários: Criptografia (AES), ACLs, Classificação de dados e MFA.

📌 Integridade: Garantia de Não Alteração e Confiabilidade

🏠 **Analogia Intuitiva:** O lacre plástico numerado de uma urna eleitoral ou a fita adesiva holográfica de uma embalagem de medicamento. Se alguém tentar abrir a tampa para trocar o remédio por veneno ou mexer nos votos, o selo se rompe irreversivelmente, provando ao destinatário que o produto foi adulterado no trajeto.

🔍 **Causa Raiz / Por que foi criado:** Arquivos e mensagens trafegando pela internet estão vulneráveis a corrupção acidental por falhas de transmissão e a ataques intencionais de Man-in-the-Middle (MitM) ou injeção de código, onde o invasor altera valores bancários ou infecta instaladores legítimos com malware.

🛡️ **Visão do Auditor de GRC:** O auditor verifica o uso de assinaturas digitais, funções hash resistentes a colisão (SHA-256) e ferramentas de Monitoramento de Integridade de Arquivos (FIM - File Integrity Monitoring como Tripwire) que alertam imediatamente sobre qualquer modificação não autorizada em arquivos de sistema ou banco de dados.

⚠️ **Como cai na Prova CompTIA:** Gatilhos da prova: 'Attacker alters transaction amount', 'Verify that downloaded file was not corrupted or modified', 'Detect unauthorized file alterations'. Propriedade: Integridade. Mecanismos: Hashing (SHA-256), Assinatura Digital, FIM. ATENÇÃO: Hashing NÃO provê confidencialidade!

📌 Disponibilidade: Acesso Contínuo e Confiável aos Serviços

🏠 **Analogia Intuitiva:** Uma UTI hospitalar que possui duas redes elétricas independentes, gerador a diesel de acionamento imediato com tanque de combustível cheio, e no-breaks (UPS) com baterias em cada leito. Se a companhia de luz da cidade inteira sofrer um blecaute, os respiradores dos pacientes continuam funcionando sem piscar.

🔍 **Causa Raiz / Por que foi criado:** Servidores físicos queimam, cabos de fibra ótica submarinos são rompidos, desastres naturais alagam datacenters e criminosos lançam ataques massivos de negação de serviço (DDoS) para exaurir a largura de banda e derrubar empresas.

🛡️ **Visão do Auditor de GRC:** O auditor fiscaliza métricas de resiliência e contratos de nível de serviço (SLA): analisa tempos de recuperação RTO (Recovery Time Objective) e RPO (Recovery Point Objective), arquitetura redundante (RAID, balanceadores de carga, clusters de alta disponibilidade) e validação periódica da regra de backup 3-2-1.

> ⚠️ **Como cai na Prova CompTIA:** Gatilhos da prova: 'DDoS attack overwhelms web server', 'Hard drive crashes halting database operations', 'Power outage takes down headquarters'. Propriedade violada: Disponibilidade. Respostas corretas: Redundancy, High Availability (HA), Load balancing, RAID, Failover, Backups, Centros de mitigação DDoS.

📌 Equilíbrio e Trade-offs da Tríade CIA

🏠 **Analogia Intuitiva:** Imagine um cofre com 15 fechaduras complexas, 3 leitores biométricos e senhas de 40 dígitos trocadas a cada hora. A confidencialidade é máxima, mas se um funcionário precisar retirar um documento com urgência durante um resgate, o tempo excessivo de desbloqueio causa um desastre por falta de disponibilidade e usabilidade.

🔍 **Causa Raiz / Por que foi criado:** Controles de segurança excessivamente burocráticos ou lentos criam atrito operacional tão severo que os usuários passam a burlar as regras de segurança (usando ferramentas não homologadas - Shadow IT), destruindo a postura defensiva da empresa.

🛡️ **Visão do Auditor de GRC:** Na governança corporativa, o auditor avalia se o custo financeiro e o impacto na produtividade do negócio estão alinhados ao apetite ao risco definido pelo conselho de administração da empresa (Framework NIST CSF - Função Govern).

> ⚠️ **Como cai na Prova CompTIA:** A banca CompTIA adora cobrar soluções que equilibrem segurança e usabilidade: implementar controles que inviabilizem a operação comercial é incorreto; a resposta ideal sempre protege a Tríade CIA mitigando o risco sem paralisar o fluxo de negócios.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Invasor captura pacotes em rede Wi-Fi aberta e visualiza senhas em texto claro	**Quebra de Confidencialidade (Mitigação: Criptografia WPA3 / TLS)**
Malware altera silenciosamente o código de barras de faturas emitidas por e-mail	**Quebra de Integridade (Mitigação: Hashing SHA-256 / Assinatura Digital)**
Ataque volumétrico de negação de serviço (DDoS) deixa o portal de clientes inacessível	**Quebra de Disponibilidade (Mitigação: Redundância / CDN / Anti-DDoS)**
Um disco de servidor queima, mas o array continua operando sem perda de dados	**Preservação da Disponibilidade (Mecanismo: RAID e Redundância)**
Validação de checksum SHA-256 de uma imagem ISO baixada do site do fabricante	**Garantia de Integridade (Mecanismo: Cryptographic Hash)**
Classificação de documentos e controle de acesso restrito a dados confidenciais	**Garantia de Confidencialidade (Mecanismo: Least Privilege & DLP)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

A equipe de TI de um hospital descobre que um notebook emprestado a um auditor externo foi roubado de um carro alugado. O notebook continha planilhas sem criptografia com nomes de pacientes, diagnósticos e números de identificação do seguro. Para garantir que quem encontrar ou comprar o dispositivo roubado não consiga ler os arquivos sigilosos, qual controle a equipe deve implantar em todos os notebooks móveis a partir de agora?

A) Listas de controle de acesso (ACLs) NTFS restritivas nas pastas das planilhas

B) Criptografia de disco completo usando AES-256

C) Regras de firewall no host bloqueando conexões de entrada

D) Backups noturnos replicados para um datacenter externo

QUESTÃO 2 · CENÁRIO DE EXAME

Uma administradora de sistemas precisa baixar uma imagem ISO de uma distribuição Linux enquanto o site principal do fornecedor está offline, e por isso passa a usar um espelho de terceiros. Ela possui o digest oficial SHA-256 do fornecedor, obtido em sua página de anúncios verificada. Qual ação fornece a evidência mais forte de que a ISO baixada não foi modificada nem corrompida?

A) Verificar se a ISO abre sem erros no utilitário de gravação de disco

B) Criptografar a ISO com AES-256 antes de salvá-la

C) Calcular o hash SHA-256 do arquivo e compará-lo com o digest publicado pelo fornecedor

D) Confirmar que a sessão de download utilizou TLS

QUESTÃO 3 · CENÁRIO DE EXAME

Durante a venda de fim de ano do ano passado, o único servidor web que hospedava a página de checkout de um varejista travou, e os clientes não conseguiram concluir compras por três horas. A diretoria agora exige uma solução que impeça uma única falha de hardware de derrubar novamente a loja online. Qual controle atende diretamente a essa exigência?

A) Implantar um cluster de servidores redundante com failover automático

B) Exigir que os clientes concluam o MFA antes do checkout

C) Habilitar criptografia AES-256 para todo o tráfego de checkout

D) Assinar digitalmente cada confirmação de pedido com a chave privada da empresa

QUESTÃO 4 · CENÁRIO DE EXAME

Uma gerente de compras de uma indústria aprovou um grande pedido de equipamentos enviando um purchase order por e-mail ao fornecedor. Semanas depois, ela nega ter autorizado o pedido, e o fornecedor exige provas. A partir de agora, a empresa quer que os purchase orders sejam protegidos de forma que a aprovadora não possa negar o envio posteriormente e que qualquer alteração no documento seja detectável. Qual controle atende aos dois requisitos?

A) Criptografar cada purchase order com uma senha compartilhada AES

B) Gerar o hash de cada purchase order e armazenar o digest em uma pasta compartilhada da equipe

C) Transmitir purchase orders apenas por um túnel IPsec

D) Assinar digitalmente cada purchase order com a chave privada da aprovadora

QUESTÃO 5 · CENÁRIO DE EXAME

Após uma campanha de phishing, invasores fizeram login com sucesso em várias contas de webmail do departamento financeiro usando nomes de usuário e senhas colhidos. As regras de complexidade de senha já são aplicadas e todas as sessões usam TLS. Qual controle impediria mais diretamente a autenticação usando apenas as credenciais roubadas?

A) Aumentar o comprimento mínimo da senha de 12 para 16 caracteres

B) Implementar MFA exigindo um código TOTP ou uma chave de segurança de hardware

C) Migrar o portal de webmail para um conjunto de cifras TLS mais forte

D) Implantar um cluster redundante de servidores de e-mail para failover

QUESTÃO 6 · CENÁRIO DE EXAME

Uma equipe forense que investiga um incidente interno teme que um administrador com acesso aos servidores altere silenciosamente os logs de auditoria para apagar os rastros. Qual controle garante melhor que qualquer adulteração dos logs armazenados será detectada?

A) Gravar os logs em armazenamento WORM e registrar hashes incrementais de cada entrada

B) Criptografar os arquivos de log com AES-256 mantendo as chaves de descriptografia no mesmo servidor

C) Configurar RAID 6 no volume de logs para sobreviver a falhas de disco

D) Comprimir os logs todas as noites e arquivá-los em um compartilhamento interno

QUESTÃO 7 · CENÁRIO DE EXAME

Ransomware criptografou o servidor de arquivos principal de um estúdio de design. Os designers ficaram sem acesso aos arquivos de projetos por quase todo o dia, até que a equipe de operações restaurou tudo a partir dos backups da noite anterior. Qual objetivo da tríade CIA é mais diretamente demonstrado pela capacidade de restaurar o serviço a partir dos backups?

A) Não-repúdio

B) Integridade

C) Disponibilidade

D) Confidencialidade

QUESTÃO 8 · CENÁRIO DE EXAME

Uma auditoria interna constata que arquivos da folha de pagamento no servidor de RH podem ser abertos por funcionários de todos os departamentos. Os dados estão criptografados em repouso e são transmitidos via TLS. Qual mudança garante diretamente que apenas a equipe autorizada do RH possa visualizar os dados da folha?

A) Aplicar ACLs que concedam permissões de pasta somente ao grupo de segurança do RH

B) Atualizar a cifra em repouso de AES-128 para AES-256

C) Configurar nós ativos/passivos de failover para o servidor de RH

D) Publicar na intranet o digest SHA-256 de cada arquivo da folha

QUESTÃO 9 · CENÁRIO DE EXAME

Desenvolvedores estão construindo um portal cliente que precisa trocar uma chave simétrica com segurança com cada navegador pela internet e depois criptografar megabytes de documentos enviados por sessão. Qual abordagem criptográfica melhor atende a esses requisitos?

A) Criptografar cada documento enviado diretamente com RSA, já que algoritmos assimétricos são sempre mais fortes

B) Usar RSA para proteger a troca da chave de sessão simétrica e AES-256 para criptografar os documentos enviados

C) Incorporar uma única chave AES estática no código de todos os clientes para eliminar a troca de chaves

D) Aplicar SHA-256 a cada documento enviado e transmitir o digest junto com o texto cifrado

QUESTÃO 10 · CENÁRIO DE EXAME

Funcionários instalam o agente de gerenciamento de um fornecedor a partir do portal de downloads do próprio fornecedor. A segurança quer a garantia de que o instalador não foi modificado e que foi realmente emitido pelo fornecedor, mesmo que um espelho parceiro que hospeda o arquivo esteja comprometido. Qual método de verificação fornece isso?

A) Confirmar que o link de download usa HTTPS antes de salvar o arquivo

B) Comparar o tamanho do instalador com o tamanho exibido no portal

C) Testar o instalador em uma VM de laboratório e confirmar que ele inicia sem erros

D) Validar a assinatura digital do instalador contra o certificado de assinatura de código do fornecedor

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Criptografia de disco completo usando AES-256

A criptografia de disco completo (por exemplo, AES-256 com chaves vinculadas ao TPM) protege diretamente a CONFIDENCIALIDADE: mesmo que o ladrão remova o disco ou inicialize outro sistema operacional, os dados permanecem ilegíveis sem a chave. As ACLs NTFS (A) restringem o acesso pelo sistema operacional em execução, mas são contornadas inicializando-se por mídia externa ou lendo o disco em outro equipamento. Regras de firewall (C) apenas filtram tráfego de rede e não protegem um dispositivo roubado offline. Backups noturnos (D) sustentam a DISPONIBILIDADE e a recuperação, não o sigilo dos dados em um notebook roubado.

Questão 2: Alternativa C — Calcular o hash SHA-256 do arquivo e compará-lo com o digest publicado pelo fornecedor

Comparar o hash SHA-256 calculado do arquivo baixado com o digest publicado pelo fornecedor é a verificação clássica de INTEGRIDADE: a alteração de um único bit produz um hash totalmente diferente, revelando adulteração ou corrupção. Abrir o arquivo no utilitário de gravação (A) confirma apenas que ele inicia, não que seu conteúdo é autêntico. A criptografia AES-256 (B) oferece confidencialidade, não integridade. O TLS (D) protege a transferência em trânsito, mas não revela que um espelho comprometido está servindo um arquivo substituído.

Questão 3: Alternativa A — Implantar um cluster de servidores redundante com failover automático

Um cluster redundante com failover automático eleva diretamente a DISPONIBILIDADE: se um nó falhar, outro atende imediatamente à página de checkout, eliminando o ponto único de falha que causou a interrupção. O MFA (B) e o AES-256 (C) são controles de confidencialidade/autenticação que nada fazem para manter o site no ar após uma falha de hardware. Assinar digitalmente confirmações (D) sustenta a integridade e o não-repúdio dos pedidos, mas não o tempo de atividade.

Questão 4: Alternativa D — Assinar digitalmente cada purchase order com a chave privada da aprovadora

A assinatura digital criada com a chave privada da aprovadora fornece INTEGRIDADE (qualquer alteração quebra a assinatura), autenticação e NÃO-REPÚDIO: ela não pode negar credivelmente a autoria, pois somente a chave privada dela poderia produzir a assinatura válida. Uma senha AES compartilhada (A) não prova quem criou o documento, já que a chave é comum. Um hash puro em pasta compartilhada (B) prova o conteúdo, mas não o vincula à identidade do signatário. Um túnel IPsec (C) protege a confidencialidade em trânsito, mas não deixa evidência posterior de autoria.

Questão 5: Alternativa B — Implementar MFA exigindo um código TOTP ou uma chave de segurança de hardware

O MFA acrescenta um segundo fator independente (algo que você tem, como um TOTP ou chave de hardware), de modo que a senha roubada sozinha é insuficiente para autenticar; essa é uma proteção direta da confidencialidade/autenticação contra roubo de credenciais. Uma senha mais longa (A) eleva o nível, mas continua sendo um único fator que os invasores já possuem. Mudar o conjunto de cifras TLS (C) protege dados em trânsito, não o processo de login atacado. Servidores de e-mail redundantes (D) são um controle de DISPONIBILIDADE, sem relação com credenciais roubadas.

Questão 6: Alternativa A — Gravar os logs em armazenamento WORM e registrar hashes incrementais de cada entrada

O armazenamento WORM (gravar uma vez, ler muitas) impede edições silenciosas, e os hashes incrementais encadeiam cada entrada de log, de modo que qualquer modificação altera o digest; esse é o requisito central de INTEGRIDADE para logs à prova de adulteração. A criptografia AES-256 (B) oferece confidencialidade, mas o próprio administrador detém as chaves no servidor e pode recriptografar versões modificadas. O RAID 6 (C) defendede a DISPONIBILIDADE contra perda de disco enquanto preserva (replica) fielmente alterações maliciosas. Compressão e arquivamento noturnos (D) não restringem gravações nem detectam modificações.

Questão 7: Alternativa C — Disponibilidade

A pergunta definidora da DISPONIBILIDADE é se os dados e serviços estão acessíveis quando necessário; backups, especialmente offline ou imutáveis, são o controle primário de recuperação que devolve o serviço ao ar após destruição ou ransomware. A integridade (B) seria a preocupação se os arquivos tivessem sido alterados silenciosamente e exigissem comparação de hashes para detectar a mudança. A confidencialidade (D) trata de manter os dados sigilosos, e o não-repúdio (A) de provar quem executou uma ação; nenhum descreve o que a restauração demonstrou.

Questão 8: Alternativa A — Aplicar ACLs que concedam permissões de pasta somente ao grupo de segurança do RH

ACLs que implementam o menor privilégio restringem quais contas podem abrir a pasta da folha; o controle de acesso no servidor compartilhado é a correção direta de CONFIDENCIALIDADE para permissões excessivamente amplas. Uma

chave AES mais longa (B) só importa se o atacante já tiver contornado a autorização e detiver o texto cifrado; a exposição aqui está na autorização, não na força da chave. Nós de failover (C) tratam da DISPONIBILIDADE. Publicar digests SHA-256 (D) apoia a INTEGRIDADE, permitindo que destinatários detectem alterações, mas não impede a leitura indevida.

Questão 9: Alternativa B — Usar RSA para proteger a troca da chave de sessão simétrica e AES-256 para criptografar os documentos enviados

Este é o padrão do sistema criptográfico híbrido: o RSA (assimétrico) resolve o problema da troca segura de chaves, pois apenas o detentor da chave privada recupera a chave de sessão, enquanto o AES-256 (simétrico) criptografa grandes volumes de forma rápida e escalável. Criptografar cada documento com RSA (A) é ordens de magnitude mais lento e impraticável para arquivos grandes. Uma chave AES estática compilada em todos os clientes (C) anula o objetivo da troca de chaves e se desfaz assim que um cliente é comprometido. O SHA-256 (D) fornece verificação de integridade do conteúdo, não confidencialidade nem troca de chaves.

Questão 10: Alternativa D — Validar a assinatura digital do instalador contra o certificado de assinatura de código do fornecedor

Um certificado de assinatura de código permite que qualquer cliente verifique o instalador com a chave pública do fornecedor: a assinatura falha se um único byte mudar (INTEGRIDADE), e a cadeia de certificados prova a identidade do fabricante (autenticidade), resistindo até a um espelho comprometido que sirva um binário adulterado. O HTTPS (A) apenas criptografa a transferência; se o espelho for hostil, o arquivo malicioso chega por uma conexão perfeitamente segura. O tamanho do arquivo (B) é trivial de igualar pelo atacante. Uma execução bem-sucedida em VM de laboratório (C) não comprova a procedência; malware também executa.